

Case Study: Designing a Unified Compliance, Risk & AI Governance Framework for LatticePay

Background

LatticePay is a fictional fintech organization operating in a high-risk environment where customer data, AI-driven insights, and cloud infrastructure intersect. To demonstrate a modern, integrated approach to governance, I developed a comprehensive workbook that consolidates security, risk, AI governance, and vendor management into a single operational model.

About Me

I designed this framework as an AI Trust & Safety practitioner transitioning into GRC, to demonstrate how I operationalize ISO/IEC 27001 and ISO/IEC 42001 in a fintech-style environment.

Objective

Design a governance suite that not only aligns to ISO/IEC 27001 and ISO/IEC 42001, but also:

- Enables leadership to see risk posture at a glance
- Provides audit-ready evidence trails
- Demonstrates how AI systems can be governed alongside traditional assets
- Supports realistic vendor selection and certification-readiness decisions

1. Asset Identification & Classification

I built a detailed asset inventory covering:

- Multicloud environments
- Cloudflare perimeter services
- Payroll systems
- Corporate endpoints
- CRM platforms
- Physical access systems
- Backup & recovery infrastructure
- Firewalls and security appliances

Each asset includes:

- Threats & vulnerabilities
- Inherent/residual risk
- Maturity scoring
- Clause-level ISO/NIST mappings

This basic structure mirrors how real ISMS/AIMS scopes are defined and makes it easy to trace each asset from risk to control to evidence.

2. Control Framework Integration

I created a unified Control Library that merges:

- ISO 27001 Annex A
- ISO 42001 AI lifecycle controls
- NIST CSF 2.0 categories

Each control includes:

- Control type
- Evidence requirements
- Ownership
- Maturity scoring
- Implementation status

This allows a single control to satisfy multiple frameworks, which is how real GRC teams reduce audit fatigue.

3. Risk Modeling & Visualization

The risk mapping sheet includes:

- Threat/vulnerability analysis
- Inherent vs. residual scoring
- Control, process, and evidence maturity
- Automated overall maturity scoring

A heat map highlights high-impact risks, and a dashboard summarizes posture at a glance.

4. AI Governance Integration

I developed an AI System Inventory aligned to ISO 42001, covering:

- Purpose and model type
- Data inputs/outputs
- Risk level
- Human oversight
- Monitoring requirements
- Responsible AI considerations
- Evidence requirements

This shows how AI systems can be governed using the same discipline as traditional IT assets, instead of being treated as an add-on. ISO/IEC 42001 was designed to seamlessly integrate with other major cybersecurity-relevant standards like ISO/IEC 27001 and ISO/IEC 27701; I try to honor that design intention in my approach to mock-implementation.

5. Certification-Readiness Tracking

I built a tracker that maps:

- ISO 27001 & ISO 42001 clauses
- Evidence requirements
- Evidence status
- Ownership
- Remediation timelines

This creates a clear path toward certification readiness.

6. RFI/RFP Lifecycle for Vendor Selection (vendor in scenario is “Asterion”)

To simulate a real procurement scenario, I designed a complete RFI and RFP lifecycle for selecting an ISO/IEC 42001 implementation and certification partner. I authored the RFI, RFP, vendor response template, and mock response to demonstrate end-to-end procurement governance, including independence safeguards and realistic pricing structures.

RFI Development

Using realistic procurement language, I drafted a full Request for Information that included:

- Company profile and AI operating context
- Detailed information-request categories
- Key procurement questions
- Evaluation factors and weighting
- Submission instructions and timelines

This allowed LatticePay to assess market maturity and identify qualified vendors.

RFP Development

Rani Rookwood

I then drafted a full Request for Proposal, including:

- A six-phase scope of work aligned to ISO 42001
- Required deliverables
- Proposal structure
- Evaluation methodology
- Independence and conflict-of-interest requirements
- Commercial response templates

Vendor Response Simulation (Asterion)

To demonstrate evaluation capability, I created:

- A structured vendor response template
- A full mock vendor response from Asterion
- Independence safeguards
- A realistic pricing model
- A delivery plan aligned to ISO 42001's lifecycle

Outcome

The final governance suite provides:

- A holistic view of LatticePay's security and AI governance posture
- A practical, operational toolkit for risk and compliance teams
- A consulting-grade deliverable that reflects real-world GRC expectations
- A complete vendor evaluation lifecycle demonstrating procurement governance expertise

Ultimately, this case study demonstrates that I can think and deliver like a GRC practitioner: designing frameworks, modeling risk, governing AI, and structuring vendor selection in a way that is directly usable in a real organization.

Skills Demonstrated

- ISO 27001 & ISO 42001 implementation
- NIST CSF 2.0 alignment
- AI governance & responsible AI
- Risk assessment & modeling
- Control design & evidence mapping
- Vendor risk management & procurement governance
- RFI/RFP development and scoring
- Documentation & audit-ready reporting
- Dashboarding & executive communication

Rani Rookwood